



An-Najah National University

Shield Gates

Secure Email System with Mail Gateway Filtering

Technical Documentation

The Supervisor:

Dr. Othman M. Othman & A. Dr. Prof Jehad M. Hamamreh

By:

Rama Abu-Haweleha	12219068
Rana Shiqer	12218105

Appendix B

1. Decision Thresholds

All values are on the 0.0 – 1.0 internal scale (composite × 10 = display score 0 – 10).

Threshold Constant	Value	Purpose
T_DROP / T_DELIVER	0.55 (≡ 5.5/10)	Composite score at or above this threshold → DROP; below → DELIVER
T_CAPE_HARD (R-D01)	0.70 (≡ 7.0/10)	Confirmed malware — CAPE malscore above this triggers immediate DROP
T_CAPE_SOFT (R-D13)	0.40 (≡ 4.0/10)	Suspicious sandbox flag—malscore in [0.40, 0.70] triggers DROP
SANDBOX_VETO_THRESHOLD	0.70 (≡ 7.0/10)	Any single attachment sandbox risk_score ≥ this → instant DROP before composite scoring

2. Deterministic Hard Rules

Rules are evaluated after composite scoring and may force a DROP regardless of the composite score. R-VETO fires before scoring. R-C01 fires on a high-severity model contradiction.

Rule ID	Condition / Description	Trigger Threshold	Category	Action
R-VETO	Any attachment sandbox risk_score ≥ 0.70	risk_score ≥ 0.70	Sandbox Veto	Instant DROP
R-D01	CAPE malscore (normalised) > 0.70	malscore > 7.0/10	Sandbox – CAPE	DROP
R-D02	Process injection detected by sandbox	Flag = 1	Sandbox – CAPE	DROP

R-D03	Win executable attachment + SPF + DKIM + DMARC all fail	All three auth = fail	Auth + Attachment	DROP
R-D04	Both header model and body model risk > 0.90	header > 0.90 AND body > 0.90	Model Consensus	DROP
R-D05	IP-based URL + password input form present	url_has_ip = 1 AND has_form_pwd = 1	Credential Harvest	DROP
R-D06	Double-extension executable (e.g. invoice.pdf.exe)	double_ext = 1 AND win_exec = 1	Attachment Evasion	DROP
R-D07	JavaScript eval() + <script> tag in email body	has_eval = 1 AND has_script = 1	Code Execution	DROP
R-D08	data: URI + <script> tag – inline payload delivery	has_data_uri = 1 AND has_script = 1	Code Execution	DROP
R-D09	Domain mismatch + suspicious sender TLD + SPF fail	All three conditions met	Auth + Spoofing	DROP
R-D10	Sandbox attachment dropped files AND contacted external hosts	dropped_files > 0 AND net_contact > 0	Sandbox – CAPE	DROP
R-D11	IP-based URL + body model risk > 0.85	url_has_ip = 1 AND body > 0.85	URL + Model	DROP
R-D12	3 or more URL anchor mismatches	url_mismatch_count ≥ 3	URL Deception	DROP
R-D13	CAPE malscore in suspicious range [0.40, 0.70]	4.0 ≤ malscore ≤ 7.0	Sandbox – CAPE	DROP
R-D14	Body model risk high (> 0.70) but header model clean (< 0.35)	body > 0.70 AND header < 0.35	Model Divergence	DROP

R-D15	Header model risk high (> 0.70) but body model clean (< 0.35)	header > 0.70 AND body < 0.35	Model Divergence	DROP
R-D16	Win executable + no SPF or DKIM authentication present	win_exec = 1 AND no auth	Auth + Attachment	DROP
R-D17	Office macro attachment + any auth failure (SPF or DKIM)	macro = 1 AND (spf_fail OR dkim_fail)	Macro + Auth	DROP
R-D18	Archive attachment + high body model risk (> 0.65)	archive = 1 AND body > 0.65	Archive + Model	DROP
R-D19	Future timestamp + domain mismatch	date_future = 1 AND domain_mismatch = 1	Header Anomaly	DROP
R-D20	<iframe> + <form> in email body	has_iframe = 1 AND has_form = 1	Content Injection	DROP
R-D21	Urgency score > 0.60 + fear score > 0.60 + ≥ 5 unique phishing keywords	All three thresholds met	Social Engineering	DROP
R-D22	IP-based URL + missing Message-ID header	url_has_ip = 1 AND no Message-ID	Header + URL	DROP
R-D23	Sandbox attachment contacted external hosts	net_contact > 0	Sandbox - Network	DROP
R-D24	Script file attachment (.js, .vbs, .ps1, .hta, .wsf)	attachment_script = 1	Script Attachment	DROP
R-D25	Suspicious sender TLD + urgency language (urgency > 0.40)	sus_tld = 1 AND urgency > 0.40	TLD + Social Eng.	DROP
R-D26	Excessive routing hops (> 10 Received headers)	received_hops > 10	Routing Anomaly	DROP
R-D27	Linux sandbox malscore ≥ 0.40 (4.0/10)	linux malscore ≥ 4.0/10	Sandbox - Linux	DROP

R-D28	Linux executable attachment (.elf, .sh, .bin, .run)	attachment_linux_exec = 1	Linux Attachment	DROP
R-C01	HIGH-severity model contradiction (header vs body vs attachment diverge severely)	Contradiction severity = HIGH	Contradiction	DROP

3. Adaptive Signal Weights

Composite score = $\sum(\text{signal_value} \times \text{weight}) \div \sum(\text{weights})$. All signal values are 0.0 – 1.0. Weights ≥ 2.00 are highlighted in red — they dominate the composite score.

Signal Key	Weight	Description / Interpretation
Authentication Failures		
spf_fail	1.50	SPF hard failure — sender not authorised by domain policy
dmarc_fail	1.30	DMARC policy failure — combined SPF/DKIM alignment check
dkim_fail	1.20	DKIM signature verification failure
spf_softfail	0.60	SPF soft-fail (~all) — sender possibly not authorised
Header / Sender Signals		
domain_mismatch	1.40	From display domain differs from envelope/SMTP domain
display_name_spoofing	1.20	Display name impersonates trusted entity (uses domain_mismatch value)
dkim_fail	1.20	See Authentication — listed here for context
date_is_future	0.80	Email Date header is set in the future
missing_message_id	0.60	Absent Message-ID header — RFC-mandated field missing
suspicious_tld_sender	1.10	Sender domain uses high-risk TLD (e.g. .xyz, .top, .tk)
missing_date	0.50	Date header absent

has_numeric_in_domain	0.50	Sender domain contains numbers (common in bulk/spam infrastructure)
no_dkim_signature	0.15	No DKIM header present — weak signal; many internal servers do not sign
URL Signals		
url_has_ip	1.60	URL uses a raw IP address instead of a domain name
url_mismatch	1.50	Anchor text domain differs from href domain (ratio, clamped 0-1)
url_redirect_chain_risk	1.20	URL redirect chain contains high-risk intermediate hops
url_suspicious_tld	1.00	URL domain uses a suspicious TLD (ratio, clamped 0-1)
url_encoded_excess	0.80	Excessive percent-encoding in URL — evasion technique
url_shortener	0.70	URL uses a known shortening service (e.g. bit.ly)
Content Signals		
has_form_with_password	1.70	HTML form with password input — credential harvesting indicator
has_eval	1.60	JavaScript eval() call detected in email body
has_script	1.40	HTML <script> tag present in email body
has_unescape	1.40	JavaScript unescape() call — often used for obfuscation
has_iframe	1.30	HTML <iframe> present — can embed malicious content
has_data_uri	1.20	data: URI scheme — used to deliver inline payloads
fear_score	0.90	Emotional fear language score (0-1)
obfuscated_chars	0.90	Ratio of obfuscated/unusual characters in body
has_form	0.80	Any HTML form present (weaker than has_form_with_password)
urgency_score	0.80	Urgency language score (0-1) — 'act now', 'expires today', etc.

unique_phishing_key words	0.15	Count of distinct phishing keywords, normalised to 0-1
money_symbols	0.40	Count of money symbols (\$, £, €), normalised to 0-1
subject_all_caps	0.50	Email subject is fully capitalised
curiosity_score	0.60	Curiosity-inducing language score (0-1)
subject_exclamation	0.30	Number of exclamation marks in subject (normalised)
total_phishing_keyw ords	0.05	Total phishing keyword occurrences, normalised to 0-1
Attachment & Sandbox Signals		
cape_malscore_norm	2.50	CAPE sandbox malware score, normalised 0-10 → 0-1. Highest weight in system.
cape_process_injecti on	2.50	Sandbox detected process injection behaviour (flag 0/1)
attachment_win_exe cutable	2.00	Windows executable attachment (.exe, .msi, .bat, .cmd, .lnk, .dll)
cape_behavior_risk	2.00	Sandbox aggregated behaviour risk score (0-1)
attachment_double_ext	1.80	Attachment has double extension masking executable (e.g. .pdf.exe)
body_model_risk	1.80	Body NLP model risk probability (0-1) — highest model weight
attachment_linux_exe c	1.50	Linux executable attachment (.elf, .sh, .bin, .deb, .rpm)
attachment_script	1.60	Script attachment (.ps1, .vbs, .js, .wsf, .hta)
attachment_office_m acro	1.40	Office macro-enabled document (.docm, .xlsm, .pptm, .rtf)
cape_dropped_files	1.00	Sandbox: files dropped on disk (normalised count, clamped 0-1)
attachment_archive	0.80	Archive attachment (.zip, .rar, .7z, .iso) — risk = 0.5
cape_network_conta ct	0.80	Sandbox: external network hosts contacted (normalised, clamped 0-1)
Model Outputs		

body_model_risk	1.80	NLP body model risk probability 0-1 (header.py / body.py output)
header_model_risk	1.50	NLP header model risk probability 0-1
Routing Signals		
received_from_suspicious	0.60	Received header contains suspicious relay hostname
excessive_received_headers	0.40	More than 10 Received headers — unusual routing path